

Валидация JWT

Позитивные сценарии (успешная обработка запроса)

1. Валидный JWT-токен с необходимыми полями

Описание: Пользователь предоставил корректный JWT-токен в заголовке `Authorization`.

Формат: Заголовок `Authorization: Bearer eyJhbGci...`

Действия системы:

Проверяет структуру токена (три части, разделённые точками).

Извлекает обязательные поля (`sub`, `email`, `preferred_username`, `family_name`, `given_name`) из полезной нагрузки (payload).

Авторизация проходит успешно, и запрос выполняется.

Результат: Код ответа `200 OK`.

2. Повторный запрос с одним и тем же токеном

Описание: Пользователь повторно обращается к API с уже использованным ранее токеном.

Условия: Токен был принят ранее и остаётся валидным.

Результат: Код ответа `200 OK`.

Негативные сценарии (ошибочная обработка запроса)

1. Отсутствие заголовка `Authorization`

Описание: Отсутствует заголовок `Authorization` в запросе.

Результат: Код ответа `401 Unauthorized`.

2. Пустой заголовок `Authorization`

Описание: Присутствует заголовок `Authorization`, но его значение пустое или пробельное.

Пример: Authorization: "" или Authorization: " ".

Результат: Код ответа 401 Unauthorized.

3. Неправильный формат передачи токена

Описание: Указанный токен не начинается с префикса `Bearer` или указан некорректно.

Примеры:

```
Authorization: token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXLTJ5IiwiaWF0IjoiMTY1MjY0MjY0In0=
```

```
Authorization: Basic eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXZWQifQ
```

Результат: Код ответа 401 Unauthorized.

4. Пустой токен после слова Bearer

Описание: После слова `Bearer` ничего не указано.

Пример: Authorization: Bearer

Результат: Код ответа 401 Unauthorized.

5. Некорректный формат токена

Описание: Структура токена нарушена (отсутствуют точки-разделители или неправильный формат Base64).

Пример: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.e30 (две части вместо трёх).

Результат: Код ответа 401 Unauthorized.

6. Не удаётся распарсить полезную нагрузку (Payload)

Описание: Содержимое полезной нагрузки токена не является корректным JSON.

Пример: Повреждённая полезная нагрузка, содержащая недопустимые символы или синтаксические ошибки.

Результат: Код ответа 401 Unauthorized.

7. Недостающие обязательные поля в полезной нагрузке

Описание: Один или несколько обязательных полей (sub, email, preferred_username, family_name, given_name) отсутствуют в полезной нагрузке токена.

Результат: Код ответа 401 Unauthorized.

8. Несоответствие требованиям безопасности ресурса (ограниченный доступ)

Описание: Пользователь обладает валидным токеном, но запрашивает ресурс, доступ к которому запрещён согласно правилам безопасности (например, административные права требуются для выполнения операции).

Результат: Код ответа 403 Forbidden.